

Next.js + Supabase Starter Checklist

The order I set up a new client project in: auth, keys, database policies, then deployment. Tick it top to bottom and you skip the usual setup mistakes.

By **Mohamed Dhia Arfa** · dhia-portfolio.com

1. Project & keys

- ☐ Create the Supabase project in the region closest to your users
- ☐ Copy the project URL and `anon` key into `.env.local`
- ☐ Only values meant for the browser get the `NEXT_PUBLIC_` prefix
- ☐ The `service_role` key stays server-side only: never in client code, never `NEXT_PUBLIC_`
- ☐ `.env*` is in `.gitignore`; a `.env.example` lists the names without values

2. Auth

- ☐ Use `@supabase/ssr` for App Router (cookie-based sessions)
- ☐ Separate browser and server clients
- ☐ Middleware refreshes the session on each request
- ☐ Site URL and redirect URLs set for localhost, preview and production
- ☐ Email templates (confirm, reset) customised and in the user's language
- ☐ Protected routes check the user on the server, not only in the UI

3. Database

- ☐ Schema changes as migrations (Supabase CLI), committed to git
- ☐ Row Level Security **enabled on every table**

4. Storage

- ☐ Buckets private by default; public only for truly public assets
- ☐ Storage policies mirror the table policies
- ☐ Upload size and file type limits set
- ☐ Images served resized (Next.js Image or Supabase transforms)

5. Server logic

- ☐ Mutations in Server Actions or Route Handlers, with input validation
- ☐ Rate limiting on public forms and any AI or email endpoint
- ☐ Errors logged server-side; users see a friendly message
- ☐ No secrets in error messages or client bundles

6. Before launch

- ☐ Environment variables set in Vercel for preview and production
- ☐ Metadata, Open Graph image, sitemap and robots.txt in place
- ☐ Lighthouse run on a mid-range phone profile
- ☐ Arabic / RTL layouts checked if the site is multilingual
- ☐ Backups and data export plan agreed with the client

- ☐ Policies written per action: select, insert, update, delete
- ☐ Policies tested as an anonymous user and as a second user
- ☐ Indexes on columns used in filters and joins
- ☐ TypeScript types generated from the schema and regenerated after each migration
- ☐ Free-tier limits understood (inactive free projects can be paused)
- ☐ Client has owner access to the domain, Vercel and Supabase

The one mistake that matters most: a table without Row Level Security is readable by anyone holding your public anon key, which ships in every browser. Enable RLS before inserting real data.

Need a fast, secure site or app built? **Book a free 30-min call**

dhia-portfolio.com